

ID: RUN-008 Category: Runbook Audience: IT Staff Last updated: 2026-06-01

RUN-008 - Phishing Report Triage (SOC Workflow)

Purpose

Define the triage, investigation, and response procedure for phishing emails reported by Robotix IT users. This runbook is used by L1 Service Desk staff for initial intake and by SOC/L3 analysts for investigation and remediation. Rapid, accurate triage protects Robotix IT and its users from credential theft, malware, and business email compromise (BEC).

Prerequisites / Access Needed

Requirement

Details

RobotixDesk access

To log and track INC tickets

Microsoft 365 Admin Center

Role: Security Reader (L1); Security Administrator (L2/SOC)

Microsoft Defender for Office 365

Access to Threat Explorer and Message Trace

Okta Admin Console

To review and act on potentially compromised accounts

CrowdStrike Falcon

To check endpoint for malware (SOC/L3)

Security operations email

soc@robotix.com (intake address)

Reporting Channels

Users can report phishing via:

Channel

Details

Report Phishing button

Outlook add-in - sends email to soc@robotix.com and auto-creates an INC ticket

soc@robotix.com

Direct email report

Slack #it-help or #security

Users may alert here; L1 creates ticket and relays to SOC

Phone +1 (800) 555-7866

L1 takes report, creates INC ticket, notifies SOC

Severity Classification

Before triaging, classify the report:

Severity

Criteria

Response

High

Medium

Low

User clicked a link or opened attachment; credentials may be entered; active campaign targeting multiple users

Immediate SOC escalation; treat as P1/P2

Suspicious email received; no interaction; targeted spear phish or BEC attempt

SOC investigates within 1 hour

Generic spam/junk with no indicators of compromise; user unsure if it is phishing

L1 can triage; close if confirmed spam

1. Receive and Log the Report

1. When a phishing report arrives (via Report button, email, or phone), create or locate the INC ticket in

RobotixDesk.

2. Record: - Reporter's name and UPN - Date/time email was received - Whether the user clicked any link or opened any attachment (critical question - ask explicitly) - Whether the user entered any credentials or personal information - Approximate sender address and subject line

3. Assign ticket priority: - User clicked/entered credentials -> P1/P2 - Email received, no interaction -> P3 -

Suspected spam -> P4

2. Initial L1 Triage Questions

Ask the reporting user:

1. "Did you click any link in this email?"

2. "Did you open any attachment?"

3. "Did you enter your Robotix IT username or password on any website after clicking?"

4. "Is the email still in your inbox, or did you delete it?"

5. "Did you forward this email to anyone?"

Document all answers verbatim in the ticket.

If the user clicked a link AND entered credentials: Skip to Step 6 (Account Compromise Response) immediately - do not wait for further triage.

3. Preserve the Email

Instruct the user NOT to delete the email. If they have already deleted it: - It will still be in their Deleted Items for 30 days (Exchange Online retention). - SOC can recover it via Microsoft 365 Compliance Center.

If the email is still in the inbox: 1. Advise the user to forward it as an attachment (not inline) to soc@robotix.com: - Outlook: Select email > More (...) > Forward as Attachment - this preserves email headers. 2. This is done in addition to the Report Phishing button report.

4. Escalate to SOC (Medium/High Severity)

For all Medium and High severity reports:

1. Email soc@robotix.com with the INC ticket number, reporter UPN, and your summary of the report.

2. Post in Slack #security: @soc-oncall Phishing report INC-[#####] - User [UPN] -

[brief: clicked/no click] - ticket linked

3. The on-call SOC analyst picks up the ticket within 1 hour (Medium) or 15 minutes (High/P1).

For Low severity (suspected spam): L1 may close the ticket after confirming no interaction and advising the user to mark as junk. No SOC escalation required.

5. SOC Investigation - Email Analysis

The SOC analyst performs the following investigation in Microsoft 365 Defender:

5a. Message Trace

1. Go to <https://security.microsoft.com> > Email & collaboration > Explorer (Threat Explorer).

2. Or: M365 Admin Center > Exchange Admin Center > Mail flow > Message trace.

3. Search by recipient UPN and approximate date/time.

4.

Identify: - Sender email address and display name - Sending IP address - SPF / DKIM / DMARC pass/fail status - Delivery action (Delivered / Junked / Quarantined) - Number of other recipients at Robotix IT

5b. URL and Attachment Analysis

1.

In Threat Explorer > locate the email > click to open details.

2. Review URLs tab - check each URL against Microsoft Defender's reputation.

3. Review Attachments tab - check file hash against VirusTotal (<https://www.virustotal.com>) or Microsoft

Defender intelligence.

4. Document findings: malicious / suspicious / benign.

5c. Scope Assessment - Are Other Users Affected?

1.

In Threat Explorer, search for the same sender or subject line across all recipients.

2. Check if the email was delivered to multiple Robotix IT users.

3.

If 5 or more users received the same phishing email: escalate to P1 campaign response (Step 8).

6. Account Compromise Response (If Credentials Were Entered)

This is the highest priority path. Complete all steps within 1 hour.

1.

Immediately suspend the user's Okta account (RUN-001 Step 5a) to prevent unauthorized access.

2. Clear all Okta sessions: Okta Admin > User > More Actions > Clear User Sessions.

3. Force password reset: Okta Admin > User > More Actions > Reset Password (use temp password method to ensure the attacker cannot use the reset link).

4. Check Okta System Log for any sign-ins from the user's account in the past 24-48 hours: - Okta

Admin > Reports > System Log - filter by user UPN. - Look for unusual login times, unknown devices, or unusual IP geolocation.

5. Check Microsoft 365 Audit Log for suspicious activity: - security.microsoft.com > Audit > filter by user and date. - Look for: email forwarding rules created, bulk email downloads, password changes, OAuth app grants.

6. Check CrowdStrike for malware on the user's endpoint: - Falcon console > Host Management > [User's device] > Activity - look for new detections. - If a detection is found, contain the device immediately: Host Management > Contain Host.

7. Notify the user and their manager - explain the account has been secured, what the attacker may have accessed, and next steps.

8. Remove any malicious inbox rules found in Step 5's audit log: - Exchange Admin Center > Mailboxes

> [User] > Manage email apps - or use PowerShell: powershell Get-InboxRule -Mailbox "user@robotix.com" | Where-Object {\$_.Enabled -eq \$true} Remove-InboxRule -Mailbox "user@robotix.com" -Identity "[rule name]"

9. Reactivate the user's Okta account and notify them when their access is restored.

7. Email Remediation - Delete from All Mailboxes

If the phishing email was delivered to multiple users, remove it from all inboxes:

Via Microsoft 365 Defender (preferred): 1. Go to <https://security.microsoft.com> > Email & collaboration > Explorer. 2. Locate the phishing email (search by sender, subject, or message ID). 3. Select all instances > Actions > Soft delete (moves to Deleted Items) or Hard delete (permanent, use for confirmed malware). 4. Confirm the purge action. This will remove the email from all matched mailboxes within 30 minutes.

Via Compliance Center (alternative): 1. Go to <https://compliance.microsoft.com> > Content search > New search. 2. Search for the email by subject + sender + date. 3. Review results > Actions > Purge items > select Delete items.

Document the number of mailboxes purged and message ID in the INC ticket.

8. Campaign Response (5+ Users Targeted)

If 5 or more users received the same phishing campaign:

1. Declare P2 (or P1 if credentials are believed to be compromised by multiple users).

2. Engage the full SOC team and L3 if not already involved.

3. Block the sender domain/IP in Microsoft Defender: - security.microsoft.com > Policies & rules >

Threat policies > Block/allow list > Add sender domain.

4. Consider a company-wide alert: - Post in Slack #announcements: "Security Alert: We are aware of a phishing campaign targeting Robotix IT users with emails appearing to be from [sender]. Do NOT click any links or open attachments. If you received this email, forward it to soc@robotix.com and do not interact with it."

5. Proceed with Steps 6 and 7 for all confirmed-interaction users.

9. Close the Ticket

1. Document all investigation steps, findings, and actions taken in the INC ticket.

2. Record: IOCs (indicators of compromise) found - sender IPs, URLs, file hashes.

3.

4.

If remediation is complete: set ticket status to Resolved.

If additional monitoring is needed: set ticket to Pending with a follow-up task.

5. Category: Security / Sub-category: Phishing.

IOC Reference Table (Document in Ticket)

IOC Type

Value (Example)

Action Taken

Sender email

boss@malicious-domain.io

Blocked in Defender allow/block list

Sending IP

185.220.101.42

Blocked

Phishing URL

https://fake-login.example.com/okta

Attachment hash (SHA256)

a3f4c1...

Verification

URL blocked in Defender; submitted to Microsoft

Submitted to Defender / VirusTotal

Check

Expected Result

Phishing email removed from all mailboxes

Confirmed via Threat Explorer - no more instances

Sender/domain blocked

Listed in Defender block list

Compromised user account secured

Okta status Active; new password set; sessions cleared; no malicious inbox rules

CrowdStrike - endpoint clean

No active detections on user's device

Ticket documented

All steps, IOCs, and actions logged

Escalation

Condition

Escalate To

Contact

Active compromise - credentials entered

SOC immediately

Malware on endpoint

SOC + L3

soc@robotix.com / +1 (800) 555-7866 x3

soc@robotix.com; contain device in Falcon

BEC - wire transfer or financial fraud initiated

SOC + Finance + Legal immediately

soc@robotix.com; notify CFO / Finance Director

Campaign targeting >10 users

P1 - Major Incident process

RUN-007

Microsoft Defender or Compliance Portal issues

L3 or Microsoft Support

See vendor-support-contacts.md

Robotix IT Service Desk · Synthetic knowledge base · This document is fictional sample data.

Robotix Technologies — Internal IT Documentation · Synthetic data, no PII.